YORU 夜 · VERSÃO 1.3.0

O que ficou mais seguro na 1.3.0

Todos os reforços de segurança feitos desde a 1.2.4, explicados um a um: o que era o risco, o que mudou e como foi conferido.

Em resumo: a 1.3.0 passou por uma revisão de segurança do código (27 de outubro), por uma auditoria com ferramentas automáticas (29 de outubro) e por uma segunda conferência manual. **Nenhuma falha de gravidade média ou alta foi confirmada.** Os pontos reais encontrados eram de gravidade baixa, e todos estão corrigidos nesta versão, cada um com um teste automático que falharia se o problema voltasse.

No fim, com a mesma franqueza, está o que ainda não está garantido.

Yoru 1.3.0, 30 de outubro de 2026. Complementa o guia *Como o Yoru protege você* (Seguranca-do-Yoru.pdf), que explica a proteção de base. Fontes: docs/seguranca.md, docs/auditoria-2026-10-29.md e o registro de mudanças do código.

O que tem neste documento

01 **Como a 1.3.0 foi conferida** — as três rodadas de revisão

02 **O que chega de outras pessoas** — mensagens, grupos e arquivos com defeito ou maliciosos

03 **Chamadas** — microfone, câmera, toque e repasse

04 **No celular** — atender bloqueado sem abrir brecha

05 **O que fica guardado no aparelho**

06 **Contra quem tenta sobrecarregar** — limites e filas com teto

07 **O serviço online**

08 **Atualizações e o próprio app**

09 **Alertas que foram conferidos e não eram problema**

10 **O que ainda não está garantido** — com toda a franqueza

> **Como ler:** cada item traz um código (SEC-, YORU-, BUG-, A- ou NOVO-) que liga o texto ao registro técnico do projeto. REFORÇO é uma melhoria preventiva; CORREÇÃO fecha um problema real que foi encontrado.

1. Como a 1.3.0 foi conferida

Três rodadas, feitas de jeitos diferentes, para uma cobrir o ponto cego da outra.

RODADA	O QUE FOI FEITO	RESULTADO
Revisão do código (27/10)	Leitura do código com foco em quem manda dados para o Yoru: amigos, membros de grupo, a rede e o serviço online. Itens SEC-01 a SEC-15 e BUG-01 a BUG-07.	Todos os itens confirmados foram corrigidos, com teste automático para cada um.
Auditoria com ferramentas (29/10)	Semgrep (análise do código), Gitleaks (segredos esquecidos no histórico do Git) e Trivy (dependências com falhas conhecidas). 15 grupos de alertas, YORU-01 a YORU-15.	2 reforços reais de gravidade baixa (YORU-01 e YORU-08), feitos. Os outros 13 foram conferidos no código: falsos positivos ou esperados. Trivy: 0 falhas nas dependências.
Segunda conferência (29/10)	Leitura manual do resultado da auditoria e do pacote que vai para as pessoas.	2 achados novos (NOVO-01, baixo; NOVO-02, informativo), corrigidos.

> **Testes que guardam o resultado.** A 1.3.0 tem 395 testes automáticos de unidade e 8 baterias de teste do app inteiro rodando de verdade, que passaram antes do lançamento. Cada correção deste documento ganhou um teste que falha se o problema voltar.

2. O que chega de outras pessoas

Um amigo, um membro de grupo ou alguém com um app modificado pode mandar dados com defeito de propósito. O Yoru agora desconfia de mais coisas.

CORREÇÃO · SEC-05

Mensagem "envenenada" não derruba nem trava

Um texto montado de um jeito específico (por exemplo, um campo chamado `toString`) fazia o processo principal do app dar erro. Agora tudo o que vem de outra pessoa passa por um leitor próprio (`parseWireJson`) que descarta esses campos em qualquer nível.

Pela caixa do serviço online, um envelope que nunca abre era lido de novo para sempre e segurava os que vinham depois dele. Agora, depois de cinco tentativas, ele deixa de bloquear os outros (sem ser apagado), e um anexo que nunca confere é tratado como removido.

Por que importa: uma única mensagem maliciosa não consegue mais fechar o app nem impedir que você receba as próximas.

CORREÇÃO · SEC-04

Ninguém se diz dono de um grupo

Um membro não consegue mais se declarar criador de um grupo que recebeu por meio de um administrador.

CORREÇÃO · SEC-02

Versão de grupo com limites

O número de versão do grupo só aceita inteiros seguros, e um administrador só pode avançá-lo pouco a pouco. Antes, um valor absurdo podia travar as mudanças futuras do grupo.

CORREÇÃO · SEC-14

Checklist sem data do futuro

Uma marcação com data adiantada não "vence" mais todas as outras: o Yoru aceita no máximo um dia à frente do seu relógio.

CORREÇÃO · SEC-08

Arquivo da chamada não é trocado

Num chat de chamada em grupo, um participante não consegue substituir o arquivo que outra pessoa mandou.

3. Chamadas

CORREÇÃO · SEC-10

Microfone, câmera e tela desligam de verdade

Se o microfone, a câmera ou a tela compartilhada terminassem de abrir **depois** que a chamada já tinha acabado, eles podiam ficar ligados. Agora tudo o que chega atrasado é desligado na hora.

Por que importa: nada fica captando depois que você desligou.

CORREÇÃO · SEC-12

Toque de grupo só de quem pode

Quem recebe o toque de uma chamada de grupo confere se a pessoa que ligou tem permissão para chamar todo mundo. O "chamar pessoa" toca no máximo uma vez a cada 20 segundos para a mesma pessoa.

REFORÇO · A-07 E B6-C04

Repasse protegido, inclusive quando a chamada volta

Quando a ligação direta não fecha (comum no 4G), a chamada passa por um servidor de repasse. Ele só retransmite os pacotes, que continuam cifrados de ponta a ponta. As credenciais desse servidor são temporárias e agora são buscadas de novo quando a chamada tenta se reconectar.

4. No celular

CORREÇÃO · SEC-11

Atender com o celular bloqueado, sem abrir brecha

A 1.3.0 permite atender uma chamada com o celular bloqueado. Para isso não virar uma porta de entrada, o botão Atender só funciona com um código aleatório criado para aquela chamada, que só o próprio Yoru conhece. Outro app no celular não consegue mandar o Yoru "atender" nem abrir por cima do bloqueio.

Como foi conferido: um teste automático no Android e um ataque simulado num celular bloqueado: sem o código, nada foi atendido e o Yoru ficou atrás da tela de bloqueio.

REFORÇO · A-08

Microfone e câmera só durante a chamada

O aviso fixo do Yoru no Android declara uso do microfone e da câmera **apenas enquanto há uma chamada**. Fora dela, o sistema sabe que o Yoru não usa nenhum dos dois.

5. O que fica guardado no aparelho

REFORÇO · YORU-01

Cofre com conferência completa

As conversas, fotos, arquivos em andamento e o repasse ficam cifrados no disco com AES-GCM, que inclui um "selo" para detectar adulteração. Em alguns lugares, um arquivo truncado de propósito podia ser conferido com um selo mais curto que o normal. Agora o selo tem sempre o tamanho completo (16 bytes) em todos os lugares, e um teste falha se aparecer um lugar novo sem essa regra.

Gravidade baixa: explorar isso exigia já ter acesso de escrita aos arquivos do seu computador.

CORREÇÃO · SEC-15

Agendamentos dentro do cofre

Mensagens agendadas e lembretes ficavam nas preferências do app, fora do cofre. Agora ficam cifrados junto com as conversas, separados por identidade. Na primeira abertura, o que estava fora é trazido para dentro e apagado de lá.

CORREÇÃO · BUG-06 E BUG-03

Visualização única some mesmo

O conteúdo de visualização única não fica mais na memória de imagens depois de fechado. No site e no celular, abrir uma visualização única apaga a mídia do cofre, mas só se nada mais a usa.

6. Contra quem tenta sobrecarregar

Alguém com um app modificado podia tentar encher filas e travar o Yoru dos amigos. Agora tudo tem teto.

ITEM	O QUE MUDOU
SEC-01 · fila de mensagens	A fila de cada conexão tem teto de 128 mensagens e 2 MB.
SEC-13 · cancelar envio	O pedido de "cancelar arquivo" só vale para um envio em andamento da mesma conexão.
SEC-09 · repasse	O espaço do repasse é reservado ao aceitar e expira em 10 minutos.
SEC-03 · arquivos	O mesmo arquivo entra uma vez por conexão (até 16 na fila, lido só na vez dele), um envio por arquivo chegando (até 8 por conexão) e, na chamada, até 4 arquivos por pessoa e 8 no total, com tamanho somado limitado.
Serviço online · chave sem cadastro	Quem nunca entrou na versão online sai da fila por 30 minutos, em vez de gerar erros repetidos no servidor.
A-06 e A-12 · caixa do serviço online	Um anexo baixando não segura as outras mensagens, e um envelope com problema segura só os do mesmo remetente. A caixa é lida em páginas com marcador, então 50 envelopes com defeito não escondem mais o 51º.

7. O serviço online

REFORÇO · A-12

Leitura da caixa com as mesmas travas

A nova forma de ler a caixa postal (por páginas) confere as mesmas coisas da antiga: só o dono da chave, num aparelho registrado, lê a própria caixa. Quem não tem acesso recebe recusa, e o teste do banco confere isso.

REFORÇO · PRIVACIDADE

Presença sem entregar quem está com o app aberto

Para gastar menos internet, o Yoru passou a mandar o sinal de "estou online" só quando algo muda. Uma solução mais simples seria perguntar ao servidor quais aparelhos estão ativos, mas isso revelaria a qualquer um que soubesse a sua chave se você está com o app aberto, **mesmo no modo invisível**. Essa opção foi descartada de propósito.

REFORÇO

Menos lugares expostos

O site saiu do Firebase e ficou só em yoruapp.com.br. Um endereço a menos para manter e proteger.

CORREÇÃO

Recusa definitiva respeitada

Quando o serviço de mídia recusa um anexo de vez, o Yoru pausa os anexos por 30 minutos em vez de insistir, sem perder a mensagem.

8. Atualizações e o próprio app

REFORÇO · 1.3.0

Edição da Microsoft Store sem a malha de atualizações

A cópia que vem da Microsoft Store é atualizada só pela loja. Ela não guarda, não anuncia, não aceita e não repassa instaladores de amigos, nem importa um à mão. Assim, quem instala pela loja fica sempre no caminho assinado pela Microsoft.

CORREÇÃO · BUG-04

Atualização com disco cheio

Uma atualização baixando com o disco cheio derrubava o app. Agora ela só falha, com o motivo.

CORREÇÃO · NOVO-01

Só o necessário no instalador

Os testes compilados (com chaves de teste, sem valor real) podiam entrar no pacote do app. Agora ficam de fora.

REFORÇO · YORU-08

Etapas automáticas fixadas

As ferramentas que testam o código no GitHub estão fixadas numa versão exata conferida, e não numa etiqueta que pode mudar por fora.

REFORÇO · NOVO-02

Arquivos que não precisam estar no Git

Arquivos compilados do Python saíram do repositório e passam a ser ignorados.

> Continua valendo o que já existia: toda atualização, venha de um amigo ou da internet, só é instalada se tiver a assinatura do publicador do Yoru e se o arquivo bater com o código de conferência (SHA-256).

9. Alertas que foram conferidos e não eram problema

Ferramentas automáticas avisam de tudo o que parece suspeito. Cada aviso foi conferido no código.

ALERTA	POR QUE NÃO ERA PROBLEMA
YORU-02 · envio de arquivo	O nome parecia o de uma função de servidor web, mas é o "mandar arquivo a um amigo" do Yoru, com tamanho e tipo conferidos.
YORU-03 · conexão direta sem TLS	A conexão por IP não usa TLS, mas o aperto de mão do Yoru cifra tudo, confere as duas identidades e cria as chaves da sessão. TLS não acrescentaria proteção a isso.
YORU-04, 05 e 09 · scripts	Rodam só na máquina de quem desenvolve ou publica, com textos fixos, sem nada vindo de fora.
YORU-06 · expressões montadas no código	Montadas com números e textos do próprio código, escapados. Nada de outra pessoa vira expressão.
YORU-07 · tela do Android aberta a outros apps	É a tela inicial (precisa ser). O que chega por ela é conferido, e o Atender exige o código da SEC-11.
YORU-10 e 12 · dados de teste	Perfis e chaves dos testes automáticos, fora do Git e fora do app.
YORU-11, 13, 14 e 15	Nomes de teclas de acessibilidade, chaves que são públicas por natureza (Discord e a chave de publicação da Supabase, feita para o navegador) e um exemplo da documentação.

10. O que ainda não está garantido

Dizer o que falta é o que dá credibilidade ao resto.

> **Instalador do Windows sem assinatura reconhecida.** O instalador baixado do site mostra o aviso "O Windows protegeu o computador", porque não tem um certificado pago. O arquivo é conferido pelo próprio Yoru (assinatura do publicador e SHA-256), mas o Windows não sabe disso. A edição da Microsoft Store resolve para quem instalar por lá.

Pendências técnicas

- **Lançamento:** as etapas automáticas do lançamento (em outro repositório) ainda não estão fixadas por versão exata, como as dos testes (YORU-08). A mudança está pronta para aplicar.
- **SEC-12:** um app modificado ainda pode usar o "chamar pessoa" para cada membro, um a um, como qualquer membro pode. O limite de 20 segundos por pessoa segura a rajada.
- **A-08:** o microfone com a tela apagada foi corrigido no código, mas ainda não foi conferido em todos os modelos de celular.
- **A-07:** a reconexão pela rota de repasse foi testada por simulação; falta um teste real com a ligação passando só pelo repasse.
- **Cobertura da auditoria:** a varredura de dependências (Trivy) não cobre o Android nem o sistema. As dependências do app continuam conferidas pelo `npm audit`.
- **Conexão direta por IP (YORU-03):** versões até a 1.2.3 ainda usam o modo antigo. Exigir o modo novo cortaria essas versões, e isso fica para quando elas saírem de uso.

Onde ver mais

O guia *Como o Yoru protege você* explica a proteção de base em linguagem simples. Os detalhes técnicos estão em `docs/seguranca.md` e o laudo da auditoria em `docs/auditoria-2026-10-29.md`, no código do Yoru.